

CLOUD SECURITY

Security is an important part of operating workloads in the AWS Cloud. AWS provides infrastructure, services, and security capabilities that help organizations protect their applications and data. However, securing a cloud environment is a shared responsibility between AWS and the customer, with each responsible for different aspects of security.

This module introduces the AWS shared responsibility model, AWS Identity and Access Management (IAM), practices for securing AWS accounts, and methods for protecting data. It also covers AWS services and programs that help organizations manage security and support compliance requirements.

AWS Shared Responsibility Model

The **AWS shared responsibility model** explains how security responsibilities are divided between AWS and the customer. AWS is responsible for security of the cloud, while the customer is responsible for security in the cloud. The specific responsibilities of the customer vary depending on the AWS services being used and the level of control provided by those services.

AWS Responsibility: Security of the Cloud

AWS is responsible for protecting the infrastructure that runs AWS Cloud services. This includes the hardware, software, networking, and facilities that support the AWS Cloud. AWS also manages the physical security of its data centers, network infrastructure, virtualization infrastructure, and other underlying components required to deliver AWS services.

Because AWS manages these underlying components, customers do not need to maintain the physical servers, networking equipment, or facilities used to provide AWS services. This allows customers to focus on securing the resources and workloads they operate in AWS.

Customer Responsibility: Security in the Cloud

Customers are responsible for securing the resources and configurations they control within AWS. These responsibilities depend on the AWS services they use and how much control they have over those services.

For an infrastructure service such as Amazon EC2, customer responsibilities can include managing the guest operating system, installing updates and security patches, configuring applications, managing passwords and permissions, and configuring security groups and host-based firewalls. Customers are also responsible for protecting their data and managing access to their AWS resources.

Responsibility Based on the Service Model

The balance of security responsibility changes according to the type of cloud service. As AWS manages more of the underlying environment, customers generally have fewer infrastructure components to manage directly.

Infrastructure as a Service (IaaS) gives customers greater control over the cloud environment. Because of this control, customers perform more of the security configuration and management tasks. Examples presented in the module include Amazon EC2, Amazon EBS, and Amazon VPC.

Platform as a Service (PaaS) shifts more responsibility for the underlying infrastructure to AWS. AWS manages more of the supporting environment, allowing customers to focus more on their applications and data. Examples presented in the module include Amazon RDS, AWS Elastic Beanstalk, and AWS Lambda.

Software as a Service (SaaS) provides centrally hosted software that is typically accessed through a web browser, mobile application, or API. Customers use the software without managing the infrastructure that supports the service. Examples presented in the module include AWS Trusted Advisor, AWS Shield, and Amazon Chime.

The shared responsibility model therefore changes depending on the service being used. Understanding what AWS manages and what remains under customer control helps customers identify the security tasks they need to perform.

AWS Identity and Access Management (IAM)

AWS Identity and Access Management (IAM) is an AWS service used to securely control access to AWS resources. IAM helps determine who is authenticated and what they are authorized to do within an AWS account. It enables organizations to manage access without sharing the AWS account root user credentials.

IAM provides several components for managing identities and permissions:

- IAM users represent people or applications that require access to AWS resources.
- IAM groups are collections of IAM users that can share the same permissions.
- IAM roles provide temporary permissions that can be assumed by users, applications, or AWS services.
- IAM policies define permissions by specifying which actions are allowed or denied on AWS resources.

Authentication and Security Credentials

Authentication verifies the identity of a user or system attempting to access AWS. Depending on how access is performed, credentials can include a user name and password or other security credentials.

For additional protection, **multi-factor authentication (MFA)** can be used. MFA requires another authentication factor in addition to the user's regular sign-in credentials. This provides an additional layer of security if the primary credentials are compromised.

Authorization and Permissions

After an identity has been authenticated, **authorization** determines which AWS resources and actions the identity is permitted to access. IAM uses policies to define these permissions.

Permissions should follow the **principle of least privilege**, which means granting only the permissions necessary to perform required tasks. For example, a user who only needs to view information should not be given permissions to create, modify, or delete resources.

IAM Policies

An **IAM policy** is a document that defines permissions for AWS resources and actions. Policies can be attached to identities such as users, groups, and roles to control what they are permitted to do.

A policy can specify the actions that are permitted or denied and the AWS resources to which those permissions apply. This allows permissions to be tailored according to the responsibilities of an identity instead of providing unrestricted access to AWS resources.

When AWS evaluates access, an **explicit allow** is required for an action to be permitted. An **explicit deny** overrides an allow. If an action is not explicitly allowed, access is denied by default.

IAM Groups

IAM groups simplify permission management when multiple IAM users require similar access. Instead of assigning the same permissions separately to each user, permissions can be assigned to a group and users can then be added to that group.

For example, users who perform similar job functions can be placed in the same group and receive permissions appropriate to that function. If the permissions associated with the group are changed, the change applies to the users who receive their permissions through that group.

IAM Roles

IAM roles provide permissions without requiring permanent credentials to be assigned to the entity using the role. A role can be assumed when access is needed and provides temporary security credentials based on the permissions assigned to it.

Roles are useful when AWS services, applications, or users need temporary access to AWS resources. For example, an AWS service can assume a role that provides the permissions required to interact with another AWS resource without storing permanent credentials.

Securing a New AWS Account

A newly created AWS account provides access to AWS services and resources, but several security measures should be established before the account is used extensively. One of the most important considerations is protecting the AWS account root user, which has complete access to the account.

Initial account security focuses on protecting highly privileged credentials, maintaining appropriate account information, and establishing visibility into activities performed within the AWS account.

Protecting the AWS Account Root User

The **root user** has complete access to all AWS services and resources in the account. Some sensitive account-level tasks specifically require root user credentials. Because of these privileges, the root user should be reserved for tasks that require it rather than used for everyday activities.

Important precautions include:

- Use a strong and unique root user password.
- Enable multi-factor authentication (MFA) for the root user.
- Keep root user credentials private and secure.
- Do not create root user access keys unless specifically required.
- Use the root user only for tasks that require root user credentials.

These practices reduce unnecessary exposure of credentials that provide unrestricted access to the AWS account.

Maintaining Account Contact Information

AWS uses account contact information to communicate with the account owner regarding account, billing, operations, and security matters. Keeping this information accurate and current helps ensure that important AWS communications reach the appropriate people.

Organizations should maintain contact information that remains accessible when responsibilities or personnel change. This is particularly important for security-related notifications that may require timely attention.

Establishing Visibility into Account Activity

AWS provides mechanisms for reviewing activities performed within an account. AWS CloudTrail records actions performed through AWS services and can provide information about the identity that performed an action, when the activity occurred, and which resources were involved.

Reviewing account activity can support auditing, troubleshooting, and investigation of unexpected actions. Billing and usage information can also provide additional visibility because unexpected resource usage or charges may indicate activity that should be investigated.

Together, these measures provide an initial security foundation for an AWS account before additional resources and workloads are deployed.

Securing Accounts

AWS provides security services that address different requirements beyond the initial protection of an individual AWS account. These services can help organizations centrally manage multiple accounts, establish organization-wide permission boundaries, manage cryptographic keys, control access for application users, and protect applications against certain types of attacks.

AWS Organizations

AWS Organizations enables organizations to centrally manage multiple AWS accounts. Accounts can be arranged into organizational units (OUs) according to business, operational, or security requirements.

This structure allows related accounts to be managed together rather than independently. For example, accounts used for similar purposes can be placed within the same OU so that organizational controls can be applied consistently. AWS Organizations also supports consolidated billing, which combines billing information across accounts while allowing the accounts to remain separate.

Service Control Policies

Service control policies (SCPs) provide centralized controls over the maximum permissions available to accounts within AWS Organizations. SCPs can be applied to an organization, organizational unit, or individual member account.

An SCP does not grant permissions. Instead, it establishes boundaries within which permissions can be granted. If an action is restricted by an applicable SCP, granting that action through another permissions policy

does not make it available. This allows organizations to establish consistent restrictions across multiple AWS accounts.

For example, an organization can use an SCP to restrict access to particular AWS services across selected member accounts. The individual accounts can still manage their own permissions, but those permissions must remain within the boundaries established by the applicable SCP.

AWS Key Management Service

AWS Key Management Service (AWS KMS) helps organizations create and manage cryptographic keys used to protect data. AWS KMS integrates with many AWS services, allowing these keys to be used when encrypting AWS resources and application data.

Organizations can control who is permitted to administer or use particular keys. AWS KMS also integrates with AWS CloudTrail so that activities involving keys can be recorded. The service uses hardware security modules (HSMs) to help protect cryptographic key material.

This centralized approach helps organizations manage encryption keys separately from the data they protect while controlling and monitoring how those keys are used.

Amazon Cognito

Amazon Cognito provides identity capabilities for web and mobile applications. It supports functions such as user sign-up, sign-in, and access control, allowing applications to provide authenticated access to their users.

Unlike IAM, Amazon Cognito is focused on managing identities for users of applications. This makes it useful when an application needs its own user registration and authentication capabilities.

For example, a web or mobile application can use Amazon Cognito to allow its users to create accounts and sign in before accessing application features or resources.

AWS Shield

AWS Shield is a managed service that helps protect applications running on AWS against distributed denial-of-service (DDoS) attacks. These attacks attempt to disrupt the availability of an application or service by overwhelming it with malicious traffic.

AWS Shield Standard provides protection against common network and transport layer DDoS attacks at no additional charge. AWS Shield Advanced provides additional DDoS protection capabilities for organizations with greater protection requirements.

Securing Data on AWS

Protecting data is an important part of cloud security. Data may need protection while it is stored in AWS and while it is being transmitted between systems. AWS provides services and security features that support encryption and help customers control access to their data. Data protection can generally be considered in two states: data at rest and data in transit, with different security mechanisms applied depending on where the data is located and how it is being used.

Protecting Data at Rest

Data at rest refers to data that is stored rather than actively moving between systems. Encryption can be used to transform stored data into a form that cannot be easily understood without the appropriate encryption key.

Several AWS services support encryption of stored data, including:

- Amazon S3 for object storage
- Amazon EBS for block storage
- Amazon EFS for file storage
- Amazon RDS for relational databases

Encryption helps protect stored information if unauthorized access to the underlying data occurs. The way encryption is configured can vary depending on the AWS service being used.

Protecting Data in Transit

Data in transit refers to data that is moving between systems, applications, or network locations. Because information can be exposed while being transmitted, secure communication protocols can be used to protect it.

AWS supports Transport Layer Security (TLS) and Secure Sockets Layer (SSL) to encrypt data while it travels across a network. **Hypertext Transfer Protocol Secure (HTTPS)** uses encrypted communication to help protect information exchanged between clients and services.

AWS also provides **AWS Certificate Manager (ACM)**, which can be used to provision and manage SSL/TLS certificates for supported AWS services. These certificates help establish encrypted connections and verify the identity associated with a secured connection.

Securing Amazon S3 Data

Amazon Simple Storage Service (Amazon S3) stores data as objects inside buckets. Because buckets can contain important or sensitive information, access to S3 resources should be configured according to the intended use of the data.

S3 Block Public Access can be used to restrict public access to buckets and objects. New S3 buckets do not allow public access by default, helping reduce accidental exposure of stored information. Access can also be controlled through IAM policies and bucket policies. **IAM policies** specify actions that an identity is permitted to perform, while **bucket policies** define permissions directly on an S3 bucket.

Access control lists (ACLs) provide another mechanism for controlling access to S3 resources. ACLs can specify which accounts or groups are granted access to a bucket or object. In the current approach to S3 access management, ACLs are considered a legacy mechanism compared with policy-based access controls.

Encrypting Amazon S3 Objects

Encryption provides another layer of protection for objects stored in Amazon S3. S3 supports encryption for stored objects so that data can remain protected at rest.

Encryption and access control address different aspects of data protection. **Access controls** determine who can access an object, while **encryption** protects the contents of the data. Using both mechanisms allows access to be restricted while also protecting the information stored within an object.

For Amazon S3, encryption can be managed using encryption capabilities provided by the service. When encryption is applied, stored object data is encrypted and must be decrypted when it is accessed. This provides protection for the contents of objects independently of the permissions used to control access to them.

Working to Ensure Compliance

Organizations that use cloud services may need to meet security, privacy, and regulatory requirements that apply to their industry or operations. AWS supports these requirements through compliance programs, documentation, and services that help customers assess their AWS resources and obtain information about AWS security and compliance. Compliance in the AWS Cloud remains a shared responsibility, with AWS maintaining compliance for the infrastructure and services it operates while customers remain responsible for configuring and using AWS services according to requirements applicable to their workloads and data.

AWS Compliance Programs

AWS participates in a variety of **compliance programs** that help organizations address different regulatory and industry requirements. These programs generally relate to:

- Certifications and attestations
- Laws, regulations, and privacy
- Alignments and frameworks

The specific compliance requirements that apply to an organization depend on factors such as its industry, location, workloads, and types of data being processed. AWS compliance programs provide information that customers can use when evaluating how AWS supports these requirements.

AWS Config

AWS Config is a service that helps assess, audit, and evaluate the configurations of AWS resources. It provides visibility into resource configurations and records how those configurations change over time, which can support auditing and the investigation of configuration changes.

Organizations can establish requirements for how particular resources should be configured. AWS Config can help evaluate resource configurations against these requirements and identify resources that do not meet the expected configuration.

AWS Artifact

AWS Artifact provides on-demand access to AWS security and compliance documents, including reports that organizations may need when evaluating AWS compliance or performing audits. It also provides access to certain AWS agreements that customers can review, accept, and manage.

AWS Artifact therefore provides a central resource for obtaining AWS compliance reports and managing AWS agreements that may be relevant to an organization's use of AWS.

References:

- Amazon Web Services. (2022). *AWS Academy Cloud Foundations learner guide: Module 4—AWS cloud security*. Amazon Web Services.
- Amazon Web Services. (n.d.). *AWS shared responsibility model*. <https://aws.amazon.com/compliance/shared-responsibility-model/>
- Amazon Web Services. (n.d.). *Security best practices in IAM*. <https://docs.aws.amazon.com/IAM/latest/UserGuide/best-practices.html>
- Amazon Web Services. (n.d.). *Best practices to protect your account's root user*. <https://docs.aws.amazon.com/IAM/latest/UserGuide/root-user-best-practices.html>
- Amazon Web Services. (n.d.). *Service control policies (SCPs)*. https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_policies_scps.html
- Amazon Web Services. (n.d.). *Blocking public access to your Amazon S3 storage*. <https://docs.aws.amazon.com/AmazonS3/latest/userguide/access-control-block-public-access.html>
- Amazon Web Services. (n.d.). *What is AWS Config?* <https://docs.aws.amazon.com/config/latest/developerguide/WhatIsConfig.html>
- Amazon Web Services. (n.d.). *What is AWS Artifact?* <https://docs.aws.amazon.com/artifact/latest/ug/what-is-aws-artifact.html>